

PaySafe India

ISO/IEC 27001:2022 GAP ANALYSIS

Annex A Control Assessment Across Organizational, People, Physical, and Technological Themes

Document Title	PaySafe India — ISO/IEC 27001:2022 Gap Analysis
Reference Code	PSI-ISO-2026-01
Subject Organization	PaySafe India (Digital Payments, UPI, BNPL Lending & Card Processing)
Effective Date	March 2026
Document Classification	Internal — Confidential
Version	v1.0
Document Owner	Information Security & Compliance Function, PaySafe India
Portfolio Note	GRC Portfolio Project — PaySafe India is a fictional entity
Related Deliverables	Internal Audit Report — ISMS Control Effectiveness (PSI-IA-2026-04), which re-tests the twelve controls rated Non-Compliant or Partial-with-elevated-risk identified here as Red/Amber; TPRM Framework (PSI-TPRM-2026-01)

Table of Contents

<u>1. Executive Summary</u>	3
<u>2. Methodology</u>	3
<u>3. Gap Analysis Master Table, by Theme</u>	4
<u>3.1 A.5 Organizational (Controls 1–5)</u>	4
<u>3.2 A.6 People (Controls 6–10)</u>	5
<u>3.3 A.7 Physical (Controls 11–15)</u>	6
<u>3.4 A.8 Technological (Controls 16–20)</u>	7
<u>4. Overall ISO/IEC 27001 Compliance Summary</u>	8

1. Executive Summary

PaySafe India was assessed against all 20 applicable controls under ISO/IEC 27001:2022 Annex A. Of those 20 controls, 10 are rated Non-Compliant, 10 are rated Partial, and none achieved a fully Compliant rating. No theme — Organizational, People, Physical, or Technological — came out ahead of the others; the deficiencies are spread evenly across the company's governance, its people processes, its office, and its infrastructure.

The single highest-priority remediation across the entire assessment is A.8.5, Secure Authentication. PaySafe India currently runs on reused, single-factor passwords with no multi-factor authentication anywhere in its infrastructure. Every other technical fix downstream of this — role-based access, privileged access management, source code restrictions — depends on the organization first being able to verify who is actually logging in. At the theme level, A.6.2, Terms and Conditions of Employment, holds the same foundational role for the People theme: without signed NDAs, acceptable-use terms, and shadow-IT policies in place at the point of hire, PaySafe India has no contractual basis to enforce training requirements, discipline violations, or hold anyone accountable after they leave.

This is not a company with pockets of weakness. It is a company that has not yet built the governance layer security depends on, and every finding below traces back to that gap in one form or another.

2. Methodology

Each of the 20 controls in scope was assessed against a two-tier RAG-style rating: Non-Compliant (Red), where no meaningful control exists, and Partial (Amber), where some form of the control exists but falls short of the requirement — whether through incomplete documentation, inconsistent enforcement, or a policy that was written but never operationalized. It is worth stating plainly rather than leaving it implied: no control in this assessment reached a Compliant rating. Every one of PaySafe India's 20 assessed controls needs remediation.

Controls are organized under the four Annex A themes defined in ISO/IEC 27001:2022 — Organizational (A.5), People (A.6), Physical (A.7), and Technological (A.8). Each theme section opens with a synthesis of the pattern running through that theme's controls, followed by the detailed findings for each control: the requirement, PaySafe India's current state, the compliance rating, the specific gap identified, and the recommended remediation.

3. Gap Analysis Master Table, by Theme

3.1 A.5 Organizational (Controls 1–5)

Across the Organizational theme, PaySafe India treats security policy as a paperwork exercise rather than an operating discipline — and the scorecard shows it: none of the five controls in this theme reached Compliant. The two Non-Compliant findings carry the most immediate risk and should be the first priority, closed within four weeks. The absence of an access control policy (A.5.15) has already produced a real incident — an intern accessed systems using a developer's credentials, out of nothing more than curiosity — and the absence of independent review (A.5.35) means there is no external check on any finding in this report, or any other. The three Partial ratings (A.5.1, A.5.23, A.5.9) should follow once those two are resolved. In each case the pattern is the same: PaySafe India has produced some form of documentation and stopped there — a policy nobody has read, an inventory nobody keeps current, cloud governance that lives as informal notes rather than an approved policy. Writing something down is not the same as running it.

Control ID	Control Name	Requirement	PaySafe India Current State	Compliance Status	Gap	Remediation
A.5.1	Policies for Information Security	Written security policy approved by management and	A policy likely exists on paper but has never been	Partial	A security policy appears to exist, but it has never actually been	Assign a security owner to run a company-wide policy awareness session

Control ID	Control Name	Requirement	PaySafe India Current State	Compliance Status	Gap	Remediation
		communicated to all employees	communicated to employees		discussed with employees	
A.5.15	Access Control Policy	Written access control policy approved by management and communicated to all employees	An intern used a software developer's credentials out of curiosity	Non-Compliant	No access control policy exists	Assign a security owner to draft an access control policy and run an employee awareness session
A.5.23	Information Security for Cloud Services	Formal legal policy governing cloud service security	Rough documentation exists, but no formal legal policy is in place	Partial	Rough documentation exists, but a formal legal policy for cloud services and security has never been drafted	Assign a security owner to convert the existing rough documentation into a formal legal policy
A.5.9	Inventory of Information and Other Associated Assets	Maintaining an inventory of every asset that exists in the organization	Partial information about assets exists and is not refreshed when changes occur	Partial	Asset information is incomplete and isn't updated when a change happens	Assign a security owner to build a complete asset inventory with a named owner per asset, updated whenever changes occur
A.5.35	Independent Review of Information Security	Independent body conducting an audit of the company	No independent review exists	Non-Compliant	The company lacks the resources to fund an audit, and leadership shows confirmation bias against outside review	Allocate budget for an independent audit; leadership needs to become more receptive to external criticism

3.2 A.6 People (Controls 6–10)

PaySafe India's compliance posture under the People theme is critically deficient, with most controls sitting at Non-Compliant or Partial. The thread connecting all five findings is a severe disconnect between HR processes and information security — from missing pre-employment background checks to undefined offboarding obligations, the organization runs on informal, generalized practice rather than codified, enforceable protocol across the employee lifecycle. The single highest priority for remediation in this theme is A.6.2, Terms and Conditions of Employment. Formal NDAs, an Acceptable Use Policy, and a Shadow IT policy are the foundation the rest of this theme rests on: without legally binding agreements signed at the point of hire, PaySafe India has no contractual authority to mandate role-specific training (A.6.3), no legal basis to enforce a disciplinary process for security violations (A.6.4), and no way to hold anyone accountable for confidentiality once they've left (A.6.5).

Control ID	Control Name	Requirement	PaySafe India Current State	Compliance Status	Gap	Remediation
A.6.1	Screening	Pre-employment background checks	No pre-employment screening takes place	Non-Compliant	No formal checks happen before hiring for privileged-access roles	Conduct background checks before offering privileged-access roles, via authorized third-party verification agencies

Control ID	Control Name	Requirement	PaySafe India Current State	Compliance Status	Gap	Remediation
A.6.2	Terms and Conditions of Employment	NDA, Acceptable Use Policy, Shadow IT policy	No such terms-and-conditions policies (NDA, shadow IT, acceptable use) are in use	Non-Compliant	No formal NDA, shadow IT, or acceptable use policy is implemented	Draft formal NDA, shadow IT, and acceptable use policies and require signature before hiring
A.6.3	Information Security Awareness, Education and Training	All personnel receive security training relevant to their specific job functions	General security training is provided, but it is neither role-specific nor detailed	Partial	No formal, job-specific security training is given	Provide role-specific security training with periodic (quarterly) awareness training cycles
A.6.4	Disciplinary Process	A defined, documented process for how the organization responds to violations consistently and fairly	No formal, documented disciplinary process exists	Non-Compliant	The disciplinary process isn't formally documented; without a written, uniformly applied process, the company has no legal defense	Create a formal, documented disciplinary process
A.6.5	Responsibilities After Termination or Change of Employment	Information security responsibilities remain valid after an individual leaves or changes roles — obligations must be defined, communicated, and enforced, covering access revocation, asset return, and reaffirming NDA obligations	No obligations are formally defined or communicated	Partial	No documented process exists to re-verify and prune access rights when an employee leaves	Integrate the HRMS with the Identity Provider (IdP) to automate access revocation within 24 hours of the Last Working Day; conduct formal security exit briefings reminding leavers of ongoing NDA obligations

3.3 A.7 Physical (Controls 11–15)

PaySafe India's Physical theme posture is highly vulnerable, undermined by a superficial approach to facility protection. The thread running through all five findings is a lack of secure architectural planning and environmental awareness — the organization treats physical security as little more than locking doors against human intruders, missing entirely the need for structural defense-in-depth and resilience against hardware-destroying environmental hazards like fire, water, or severe weather. The single highest priority for remediation is A.7.5, Protection Against Physical and Environmental Threats. PaySafe India never conducted a formal site risk assessment before occupying its facility, which means every physical security decision made since has effectively been made in the dark. Commissioning a localized threat assessment is the foundation the rest of this theme depends on: until PaySafe India understands its specific geographic and environmental exposure, it cannot design a secure physical perimeter (A.7.1), build the right structural defenses (A.7.3), or deploy the correct environmental monitoring sensors (A.7.4).

Control ID	Control Name	Requirement	PaySafe India Current State	Compliance Status	Gap	Remediation
A.7.1	Physical Security Perimeters	Define and implement distinct physical barriers protecting areas containing sensitive information or critical processing facilities from unauthorized physical access, damage, or interference	Almost every physical security measure is in place except electronic access control	Partial	Electronic access control is missing — a critical safeguard	Implement multi-factor electronic access control combining RFID smart badges with biometric scanners, prioritizing the Server/Network Communications Room; maintain immutable entry logs restricted to authorized IT personnel
A.7.2	Physical Entry Controls	Implement secure entry mechanisms (biometric scanners, smart cards) so only authorized personnel access restricted areas, with an audit trail of entry and exit events	The organization has neither physical entry controls nor an audit trail	Non-Compliant	Secure entry mechanisms are missing, allowing unauthorized entry, with no audit trail of entries and exits	Deploy anti-tailgating barriers (turnstiles or mantraps) with biometric authentication at all primary entrances; implement digital visitor management with ID verification, temporary badges, and mandatory escorts; centralize entry logs with automated anomaly alerts
A.7.3	Securing Offices, Rooms and Facilities	Design and apply physical security measures specific to offices, rooms, and facilities to prevent unauthorized access, damage, or theft, including a clean desk policy	The organization has no physical layout or design securing against unauthorized access	Non-Compliant	The organization lacks structural defense-in-depth and a secure physical architecture — no defined security zones, environmental barriers, or layout strategy isolating sensitive areas; the clean desk policy isn't followed, which is critical for a fintech firm	Enforce the clean desk policy for every employee, not just managers, effective immediately; reinforce physical boundaries with solid-core doors, shatterproof glass, and true floor-to-ceiling walls
A.7.4	Physical Security Monitoring	Continuously monitor premises, offices, and facilities to detect and deter unauthorized physical access and environmental threats	The organization has measures against unauthorized physical access but is unprepared for environmental threats	Partial	A critical blind spot around non-human physical risk — no environmental monitoring, leaving hardware vulnerable to fire, water leaks, or HVAC failure	Deploy continuous automated environmental sensors (temperature/humidity, under-floor water leak detection, early-warning smoke alarms) in all critical processing areas, integrated into 24/7 centralized alerting; implement automated gas-based fire suppression (e.g., Novec or FM-200)

Control ID	Control Name	Requirement	PaySafe India Current State	Compliance Status	Gap	Remediation
A.7.5	Protection Against Physical and Environmental Threats	Design and implement physical protections against natural disasters, extreme weather, or civil unrest	The organization never conducted a formal site risk assessment before choosing its office location and has no documented protection measures against natural disasters or civil unrest	Non-Compliant	Lacks any foundational understanding of its geographic risk exposure, having bypassed a formal site risk assessment — leaving the facility blindly vulnerable	Commission a formal, localized site threat assessment identifying geographic vulnerabilities (flood zones, seismic activity, regional instability); develop, document, and test a physical emergency response plan for extreme weather or civil emergencies

3.4 A.8 Technological (Controls 16–20)

The Technological theme is critically deficient, marked by a systemic failure in identity and access governance. Every control in this theme traces back to the same root cause: the organization consistently prioritizes operational convenience over logical security. Shared login credentials, unmanaged personal devices under BYOD, and over-provisioned access to sensitive environments like source code all violate the principles of least privilege and need-to-know, eliminating individual accountability and rendering audit trails useless across the infrastructure. The single highest priority for remediation — across the entire assessment, not just this theme — is A.8.5, Secure Authentication. Systematically reused, single-factor passwords form a foundational vulnerability that undermines every other technological control in place. Until robust multi-factor authentication and unique, individualized credentials are enforced across every tier of personnel, secondary measures like Role-Based Access Control (A.8.3) or Privileged Access Management (A.8.2) cannot be reliably implemented — the system currently has no mathematically sound way to verify who is actually accessing the network.

Control ID	Control Name	Requirement	PaySafe India Current State	Compliance Status	Gap	Remediation
A.8.1	User Endpoint Devices	Secure all corporate information processed, stored, or accessed on user endpoint devices, both company-issued and personal BYOD	The organization secures company-issued hardware but not personal BYOD laptops or phones	Partial	Zero visibility or technical control over corporate data on unmanaged personal devices, creating risk of data leakage and malware infection	Establish and enforce a formal BYOD policy mandating security requirements for personal hardware; deploy MDM/MAM to containerize corporate data away from personal applications
A.8.2	Privileged Access Rights	Strictly restrict and manage privileged access allocation based on least privilege, with formal authorization and separation from standard accounts	The organization generally applies least privilege for standard users, but certain privileged accounts (e.g., management) maintain permanent, standing access	Partial	Fails to enforce temporary authorization and account separation for high-level users, leaving management with unmonitored, always-on standing access that bypasses formal oversight	Implement PAM to enforce Just-In-Time access and mandatory secondary approvals for elevated actions; require management to use dedicated, vaulted administrative accounts separate from daily-use email

Control ID	Control Name	Requirement	PaySafe India Current State	Compliance Status	Gap	Remediation
A.8.3	Information Access Restriction	Strictly restrict access to information in accordance with a formal Access Control Policy, enforcing need-to-know	The organization does not enforce RBAC; personnel frequently use shared login credentials and do not maintain password secrecy, violating need-to-know and compromising individual accountability	Non-Compliant	Lacks individualized logical access controls; reliance on shared, unrestricted credentials breaks need-to-know and prevents meaningful auditing	Eliminate shared accounts by provisioning unique individual credentials for every employee; implement RBAC limiting permissions to the specific data required per job function
A.8.4	Access to Source Code	Strictly restrict read and write access to source code, development tools, and libraries via secure, isolated repositories and version control, based on least privilege	Access to source code is not universal, but read/write privileges are significantly over-provisioned; non-technical personnel (HR, management) and temporary staff (interns) have unnecessary access	Partial	Severe privilege creep exposing source code to non-technical and temporary staff with no operational need, risking IP theft or accidental corruption	Conduct an immediate access audit and revoke source-code permissions from all non-development personnel; reconfigure version control to enforce strict RBAC for active developers only
A.8.5	Secure Authentication	Implement robust, risk-based authentication (e.g., MFA) enforced across all systems to prevent unauthorized access and credential compromise	The organization lacks MFA across its infrastructure; systemic credential reuse across all personnel levels (employees, HR, management) using identical or highly similar passwords	Non-Compliant	Fails to secure user identities, relying entirely on weak, reused single-factor passwords, leaving the infrastructure vulnerable to credential compromise and lateral movement	Deploy MFA universally across all systems and access points; enforce a system-level password policy preventing reuse, supported by an enterprise password manager

4. Overall ISO/IEC 27001 Compliance Summary

PaySafe India's compliance posture across all four themes — Organizational, People, Physical, and Technological — is critically deficient, and the deficiency has one connecting thread: a systemic prioritization of operational convenience over formal security governance. The company operates without defined organizational policies or a preliminary site risk assessment, relies on undocumented HR onboarding processes, and shares technological credentials across roles that should never share anything. There is no foundational framework underneath any of it. This absence of codified protocol undermines individual accountability at every level, violates the principle of least privilege throughout the infrastructure, and leaves the organization exposed — blindly, in the case of physical risk, and mechanically, in the case of intrusion.

The single highest-priority action, across the entire organization, is establishing enforceable administrative governance and stringent identity verification at the same time. PaySafe India needs to urgently codify its foundational policies — Terms and Conditions of Employment (A.6.2) chief among them, alongside a

comprehensive Access Control mandate — while universally deploying Multi-Factor Authentication and unique, individualized user credentials (A.8.5). These two fixes are not independent of each other, and they are not independent of everything else in this report. Legally binding security obligations give PaySafe India the authority to enforce compliance; robust authentication gives it the technical mechanism to actually secure the logical perimeter it is trying to defend. Without both anchors in place, every secondary remediation in this document — structural hardening of the office, Role-Based Access Control, independent audits — will sit on top of a foundation that isn't there yet, and will not hold.